

# Protección de rutas y recursos por rol

## ¿Qué es un middleware?

Un middleware es una función intermedia que se ejecuta antes de llegar a la lógica principal de una ruta en el backend.

## ¿Cómo se protegen rutas en backend?

Se protegen usando middleware que verifica la identidad del usuario.

Formas comunes:

JWT (JSON Web Token)

Se envía un token en cada petición y el servidor lo valida.

Sesiones

El servidor guarda la sesión del usuario autenticado.

Middleware de autenticación

Ejemplo:

Si el usuario no tiene token válido → acceso denegado

Si lo tiene → puede continuar

## ¿Qué errores de seguridad son comunes?

Algunos errores muy frecuentes son:

- No validar el token

- Cualquiera puede acceder

- No usar HTTPS

- Los datos pueden ser interceptados

- Exponer rutas sin protección

- Acceso libre a información sensible

● No validar datos de entrada

→ Ataques como inyección (SQL Injection)

● Tokens que no expiran

→ Riesgo si alguien roba el token

● Contraseñas sin cifrar

→ Muy peligroso

### ¿Cómo se valida acceso por rol?

Se hace combinando autenticación + autorización.

Pasos:

- El usuario inicia sesión
- El servidor genera un token con su rol (ej: admin, usuario)
- El middleware revisa:
  - Si está autenticado
  - Qué rol tiene

Ejemplo:

Ruta /admin

Middleware:

Si rol = admin → acceso permitido

Si no → acceso denegado

### ¿Para qué?

Para garantizar que:

Solo las personas autorizadas puedan acceder al sistema

Los datos estén protegidos contra accesos indebidos

El sistema sea seguro y confiable

Se eviten ataques o uso incorrecto de la información

### **¿Qué harás?**

- Implementar protección de rutas en el backend
- Validar el acceso de usuarios según su rol (admin, usuario, etc.)
- Evitar accesos directos no autorizados a rutas sensibles
- Agregar pruebas (tests) de seguridad para verificar que todo funcione correctamente

### **¿Qué aprenderás?**

- A cerrar el sistema correctamente para evitar accesos no autorizados
- A implementar un control de acceso real basado en usuarios y roles
- A pensar como ingeniero backend, priorizando la seguridad y la lógica del sistema

### **Entregables:**

- Rutas protegidas según el rol del usuario
- Evidencia de que los accesos indebidos son bloqueados
- Tests de seguridad que validen la protección del sistema
- Documentación técnica explicando cómo funciona la seguridad implementada